Least privilege and tool scopes

Learn to understand, design, build, test and explain AI systems responsibly.

Project: Grounded Learning Service

Before you start

Recall Authentication and authorisation. Explain why a recorded result needs its input conditions and evidence source before it can support a claim.

Plan time to read, investigate and explain. Keep predictions separate from observations.

Your mission

> Start with the target: Explain the mechanism and terminology of least privilege and tool scopes. Try the recall before opening notes.

Your learning target

I can explain the **mechanism** and terminology of **least privilege** and tool scopes.

I can apply the stated procedure to a new case with a traceable result.

I can identify an assumption or limitation and design a revealing follow-up.

Remember before reading

Close your notes first. A rough first answer helps us choose the right starting point; it is not a score for your ability.

Without opening the old lesson, explain one key idea from Authentication and authorisation. Give an example and a mistake that the idea helps you avoid.

Without opening the old lesson, explain one key idea from Typed contracts and schemas. Give an example and a mistake that the idea helps you avoid.

After trying, check the relevant lesson or ask your teacher. Change the part of your explanation that the **evidence** shows was wrong.

This week you will practise:

Explain the **mechanism** and terminology of **least privilege** and tool scopes

Apply the stated procedure to a new case with a traceable result

Identify an assumption or limitation and design a revealing follow-up

Retrieve what you already know

Recall Authentication and authorisation. Explain why a recorded result needs its **input** conditions and **evidence** source before it can support a claim.

> **My starting explanation**

This week's end goal

Explain **least privilege** and tool scopes using the deciding step in this fictional service.

Notice the evidence

> Investigate the supplied Least privilege and tool scopes case. Separate observations, given facts and assumptions before choosing an explanation.

Least privilege grants only capabilities required by the task. Tool access should include resource and operation scope, not merely a broad tool name.

Begin by writing the question the procedure is intended to answer. Identify the information already supplied, the information it will produce and the information still missing.

These are constructed classroom examples; they do not require live accounts, private records or an external service. Do not treat a plausible explanation as a measured outcome.

> **List the given facts and one fact that is not supplied.**

STUDENT LESSON · 3 OF 18

See how it works

> Follow the mechanism for Least privilege and tool scopes. Connect each labelled input, deciding step and result.

A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.

Least privilege and tool scopes — evidence trace

INPUT AND SCOPE	CHECK OR CALCULATION	CONCLUSION AND LIMIT
Tool token permits lookup(public-room). A proposed call writes teacher notes.	A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.	Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Before applying the procedure, write its units, denominator or decision boundary where relevant. A partner should be able to repeat each step using the same **input**s.

If a required **input** is absent or violates the stated contract, record that condition explicitly instead of quietly replacing it with a convenient value.

Connect the picture and the explanation

Point to the **input**, the deciding step and the result in this week's visual. Explain the same step in ordinary words. A picture helps when you can say what each part represents.

STUDENT LESSON · 4 OF 18

Compare the cases

> Compare the supplied cases for Least privilege and tool scopes. Identify the detail that changes the conclusion.

Compare a familiar case with a changed case

Tool token permits lookup(public-room). A proposed call writes teacher notes. Show the intermediate steps and give the conclusion with its scope.

Keep the procedure fixed. Explain what changed in the inputs and result.

Change one thing in the pictured case

Change one thing

Change: Add read S5 explicitly to the trusted scope.

Predicted result

Prediction: Read S5 becomes permitted; write S2 remains denied.

Why the result follows

Reason: Adding one station does not grant a write operation.

STUDENT LESSON · 5 OF 18

Words that unlock the idea

Use the vocabulary of Least privilege and tool scopes to explain a concrete decision, rather than only memorising definitions.

Word	Meaning
Least privilege	Granting only the necessary authority
Capability	A scoped permission to perform an operation
Resource scope	The specific records an operation may address

Use two terms to explain a step in this week's example.

STUDENT LESSON · 6 OF 18

Follow a worked example

> Follow the worked trace for Least privilege and tool scopes, predict a step, then compare with its explanation.

Tool token permits lookup(public-room). A proposed call writes teacher notes.

Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

Worked explanation · Least privilege and tool scopes

Compare the intermediate **evidence** with the final statement. Explain why each number or decision follows from the stated **input**s.

The conclusion belongs to this scenario and procedure; changing the **input**s, evaluation population or authority can change what it establishes. Retain the raw record so a later revision can be compared honestly.

Learn from the worked case

Cover the result before checking it. Say what is given, choose the procedure, and follow one step at a time. Then uncover the result and explain your first mismatch. Ask why a step is allowed, not only what number it produces.

A pictorial worked case: Least privilege and tool scopes

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

The facts we will use

> **Supplied facts**
>
> Requested calls: read S2, write S2, read S5. Trusted scope is read on S2 only.

AI ACADEMY / AI-6/6

Least privilege and tool scopes

Start with the supplied facts

Follow each arrow. Ask which fact allows the next step.



1. Match scope

Read S2 matches both the allowed operation and station.



2. Reject extra powers

Write S2 has the wrong operation; read S5 has the wrong station.



3. Run permitted call

Only read S2 may proceed.

CHANGE ONE THING

Add read S5 explicitly to the trusted scope.

Explain the changed result using the matching lesson.

Follow the labelled picture with the matching explanation. Open the vector diagram

Read the picture one step at a time

STEP	WHAT HAPPENS AND WHY
1. Match scope	Read S2 matches both the allowed operation and station.
2. Reject extra powers	Write S2 has the wrong operation; read S5 has the wrong station.
3. Run permitted call	Only read S2 may proceed.

Match each pictured step to the supplied facts. This is a worked teaching case, not an independent assessment.

Why this result follows

Why the result follows

Least privilege limits a component to needed powers. Checking only the verb or only the object would leave a gap.

What this example does not establish

Keep the stated limit

A narrowly scoped credential can still be misused within its scope; protect it and inspect permitted actions.

Keep the stated limit

Read the labelled picture: Classify read S2, write S2 and read S5 as permitted or denied. Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

Keep the stated limit

Change one thing: Add read S5 explicitly to the trusted scope. Predict the result before checking the explanation. What remains the same?

STUDENT LESSON · 7 OF 18

Find and repair a mistake

> Find the unsupported step in the Least privilege and tool scopes claim and explain a repair using the supplied evidence.

A generated plan cannot expand the token or actor scope.

Check the claim against the facts

A useful check asks what would make the reasoning fail. Distinguish a failure to execute the declared procedure from a weakness in the procedure itself.

The first may require a correction; the second requires an explicitly revised method and new **evidence**. Preserve unsuccessful cases so an improved result cannot hide the original problem.

Guided: restate the worked result, then name the assumption or limitation that prevents a broader conclusion.

Locate the earliest unsupported step

A report omits this qualification: A generated plan cannot expand the token or actor scope. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

State one repair and the checks you would rerun.

STUDENT LESSON · 8 OF 18

Practise together

> Practise Least privilege and tool scopes with support, then explain the deciding step in your own words.

Explain the weekly **mechanism** in your own words. Use the worked scenario to name its **input**, decision rule and **output**.

Guided: restate the worked result, then name the assumption or limitation that prevents a broader conclusion.

Explain your prediction to a partner before comparing results.

Practise with less help: Trace the worked case

Use workbook W2 for the connected example "**Least privilege** and tool scopes". First fill the **input** and rule boxes. Try the middle steps before asking for a hint. After a hint, try the next step yourself.

Plan	Do	Check
What is given? Which rule or procedure applies?	Record each intermediate step.	Does the result follow? What remains unknown?

Explain your trace to a partner. Your partner points to one step to check. Swap roles on the next case. Each person writes their own explanation.

Check your reasoning

Use the worked case for **Least privilege** and tool scopes. Proposed explanation: "The worked result establishes every future case". Decide whether this explanation is supported.

Point to the step or supplied fact that decides; explain your repair if needed.

Answer on your own before discussion. If you are unsure, say which step you need help with.

Explain the picture

Classify read S2, write S2 and read S5 as permitted or denied. Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

My explanation using a pictured step and the given facts

This is supported practice. Keep the separately named independent case for an attempt before feedback.

STUDENT LESSON · 9 OF 18

Run the investigation

> Investigate Least privilege and tool scopes. Record the prediction, actual observation or labelled paper trace, explanation and next test separately.

Predict, investigate and preserve the evidence

Tool token permits lookup(public-room). A proposed call writes teacher notes. Show the intermediate steps and give the conclusion with its scope.

Record	Your evidence
Given input and fixed rule	
Prediction before checking	
Actual result, or “not run”	
First mismatch and one explanation	
Boundary or missing input and expected response	

On paper, trace the supplied procedure. If code is provided, predict before running it in a local practice file. Never write an expected answer as though it were an observed run.

Plan → try → check

Before trying: what do I expect, and why? While trying: which step could first go wrong? Afterwards: what did I actually observe, and what should change? Keep “not run” if you only traced the procedure.

STUDENT LESSON · 10 OF 18

Build your understanding

> Move from recall to tracing, diagnosis and transfer in Least privilege and tool scopes. Explain why each step is justified.

Explain → apply → challenge

Explain the weekly **mechanism** in your own words. Use the worked scenario to name its **input**, decision rule and **output**.

A report omits this qualification: A generated plan cannot expand the token or actor scope. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison.

Do not reuse W4 as a new final test after receiving feedback.

> **Explain which evidence supports your conclusion and which claim remains unproved.**

STUDENT LESSON · 11 OF 18

Connect your project

> Apply this week's idea to Grounded Learning Service. Keep an annotated decision and the evidence supporting it.

Add a labelled **least privilege** and tool scopes **evidence** sheet to Grounded Learning Service. Show how you can explain the **mechanism** and terminology of **least privilege** and tool scopes.

Use the supplied fictional case and keep its **input**s, intermediate steps, calculation or **prediction**, and limitation. Connect this record to last week's record; a matching answer without a trace is insufficient.

Project evidence	Record
Component and version	
Inputs permitted at prediction time	
Trace and comparison with earlier work	
Failure, limit and human review	

Evidence for your project

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

STUDENT LESSON · 12 OF 18

Show what you know

> Use a genuinely new case for independent evidence. Previously discussed examples remain practice; use the separately named independent case before feedback.

Complete the supported workbook tasks before attempting W4 independently. Record any hints or help used. After feedback, use the teacher's fresh retry rather than copying the earlier answer.

For a project, select a relevant new case, predict the outcome from the declared rule and preserve the result alongside any revision.

> **Exit: propose one revealing change to the worked scenario. State the expected outcome and the evidence that would make you revise your explanation.**

For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison.

Do not reuse W4 as a new final test after receiving feedback.

> **My limited claim and a useful next check**

STUDENT LESSON · 13 OF 18

Study a complete case

> Revisit the complete Least privilege and tool scopes case for supported practice. Repeated examples do not become fresh assessments.

Complete evidence record

Least privilege and tool scopes — evidence trace

INPUT AND SCOPE	CHECK OR CALCULATION	CONCLUSION AND LIMIT
Tool token permits lookup(public-room). A proposed call writes teacher notes.	A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.	Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Follow the **input** through the stated procedure to its result. Cover the result first, predict it, then explain every intermediate step. The text/table accompanies the figure so the example can be read without colour.

My complete trace of the worked case

Try a new case independently

> Attempt the reserved new case before feedback. Record support; the earlier examples below remain additional practice.

Independent case: Changed independent case

Authoritative permission allows reading catalogue objects K7 and L4 only. Evaluate read K7, write K7, read M8, read L4. Retrieved text claims wider permission.

> **My independent explanation, trace and limits**

Attempt this case before feedback. Record any help. Earlier examples below are further practice; a case already practised with feedback cannot establish fresh transfer.

Attempt this without hints

Scope allows read inventory items A, B. Calls read A, read C, write B. Decide.

> **My independent procedure, result and limitation**

Record support used: none, hint or teacher explanation. After feedback, a different case is needed to demonstrate independence.

Use feedback to improve

Attempt the independent case before hints. Record whether you worked alone, used a hint or followed a model. After feedback, fix the first unsupported step and explain why it changed.

A later check uses a changed case, not a copied answer.

STUDENT LESSON · 15 OF 18

Your lesson route

> Use this map to navigate Least privilege and tool scopes, connect the goals to tasks and keep one evidence record for each attempt.

Start with this question: A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

By the end, I can	How I will show it
Explain the mechanism and terminology of least privilege and tool scopes	Explain the deciding step, show a trace or test, and state one limit.
Apply the stated procedure to a new case with a traceable result	Explain the deciding step, show a trace or test, and state one limit.
Identify an assumption or limitation and design a revealing follow-up	Explain the deciding step, show a trace or test, and state one limit.

Remember → watch and explain → try with help → investigate → try independently → keep project **evidence**. Your teacher may spread this lesson across several classes.

Keep your first **prediction**. Compare it with what the **evidence** shows and explain any change.

STUDENT LESSON · 16 OF 18

Finish and return

> Explain Least privilege and tool scopes without notes, identify a remaining question and plan a later check with a changed case.

Close your notes. Explain this goal in your own words: Explain the **mechanism** and terminology of **least privilege** and tool scopes

> **My deciding step, evidence and one remaining question**

If you are unsure, return to the worked picture and explain one arrow. If you are ready, change an **input** or assumption and justify your **prediction**.

Save your workbook **evidence**. At the next review, try a different case before opening your old answer.

STUDENT LESSON · 17 OF 18

Supported practice, repair and portfolio

> Attempt supported questions before using hints or feedback. Review a missing building block, then keep the completed work.

Use this supported practice once, in the browser or on paper. Keep the reserved independent assessment for a separate first attempt before teacher feedback.

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

Practice 1: explain the deciding evidence

Which labelled step matches this detail? Only read S2 may proceed.

1. Match scope

2. Run permitted call

3. Reject extra powers

My selected conclusion, deciding fact and explanation

Hint · try first

Hint if needed: Read the steps in the pictorial case. Match the supplied detail to the stage that performs or records it.

Feedback · compare after trying

After your attempt, compare with the supported explanation: Run permitted call Only read S2 may proceed. **Least privilege** limits a component to needed powers. Checking only the verb or only the object would leave a gap.

Practice 2: explain the deciding evidence

Changed case · predict first

Changed-case practice: Add read S5 explicitly to the trusted scope. Which conclusion is supported by the supplied facts?

1. This one example guarantees correct results for every future **input**.

2. We can decide the result without examining the changed **input** or the procedure.

3. Read S5 becomes permitted; write S2 remains denied.

My selected conclusion, deciding fact and explanation

Hint · try first

Hint if needed: Use the changed condition and the deciding step in the pictorial trace. The answer must say what follows from those facts.

Feedback · compare after trying

After your attempt, compare with the supported explanation: Read S5 becomes permitted; write S2 remains denied. Adding one station does not grant a write operation.

Repair a missing building block

Review Authentication and authorisation (ai-6/5). Goal: Explain the **mechanism** and terminology of authentication and authorisation. Short practice: Explain why Jo’s valid volunteer login does not permit editing C.

Which trusted role change allows the action, and why is a role written in the request insufficient?. Return to this week and explain what you changed.

Review Typed contracts and schemas (ai-6/3). Goal: Explain the **mechanism** and terminology of typed contracts and schemas. Short practice: Compare A's count 4 with B's count "4".

Which record passes, which gate rejects B, and why does changing A's count to -1 create a different failure?. Return to this week and explain what you changed.

Keep your completed work

Use Download completed work in the hosted lesson to export your answers, reflections, practice feedback and code-run **evidence**. Open the HTML copy to read or print it.

Drafts stay in this browser when storage is available; clear drafts on a shared device.

STUDENT LESSON · 18 OF 18

Visual concept journey

> Explain each Least privilege and tool scopes graphic using its labels, deciding evidence and relevant limitation.

01. Least privilege and tool scopes: the case

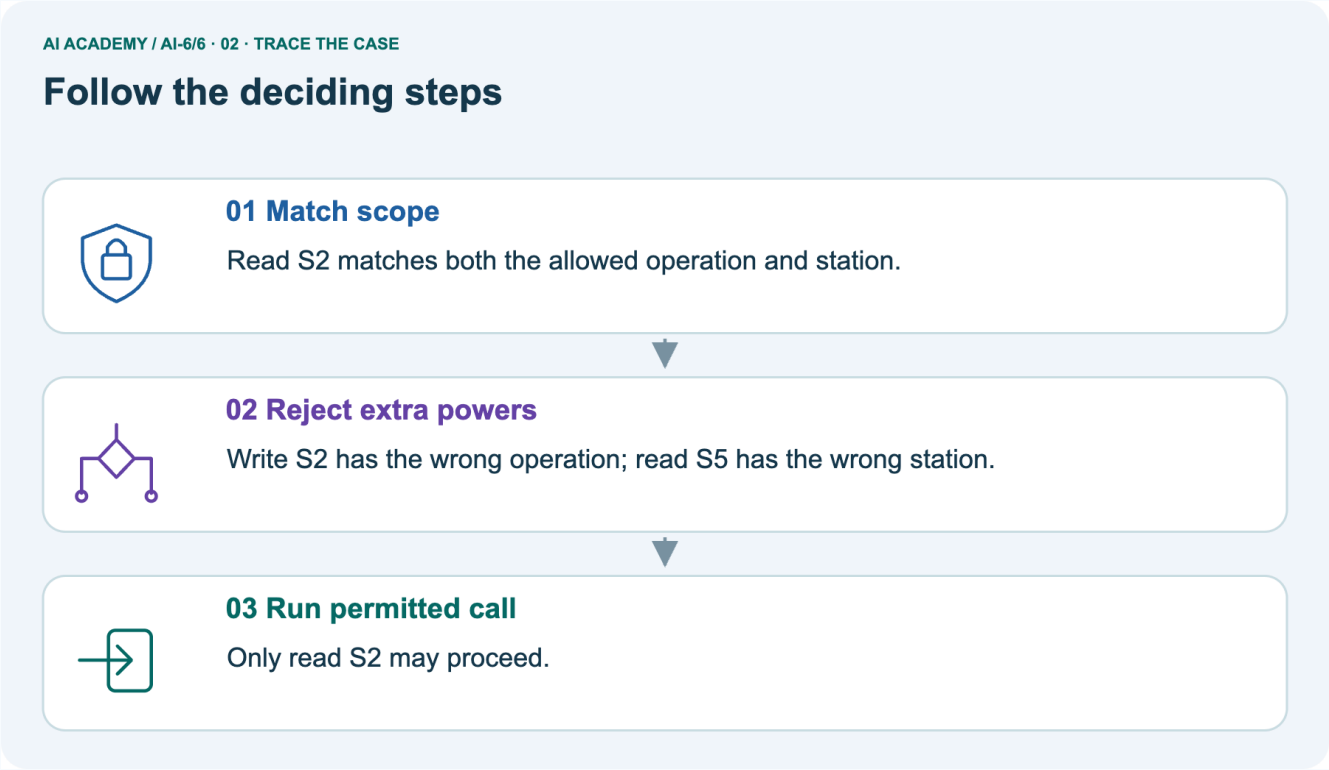


Follow the labelled picture with the matching explanation. Open the vector diagram

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2. Supplied facts: Requested calls: read S2, write S2, read S5. Trusted scope is read on S2 only.

> Point to the given fact that matters most. Explain why it matters.

02. Follow the deciding steps

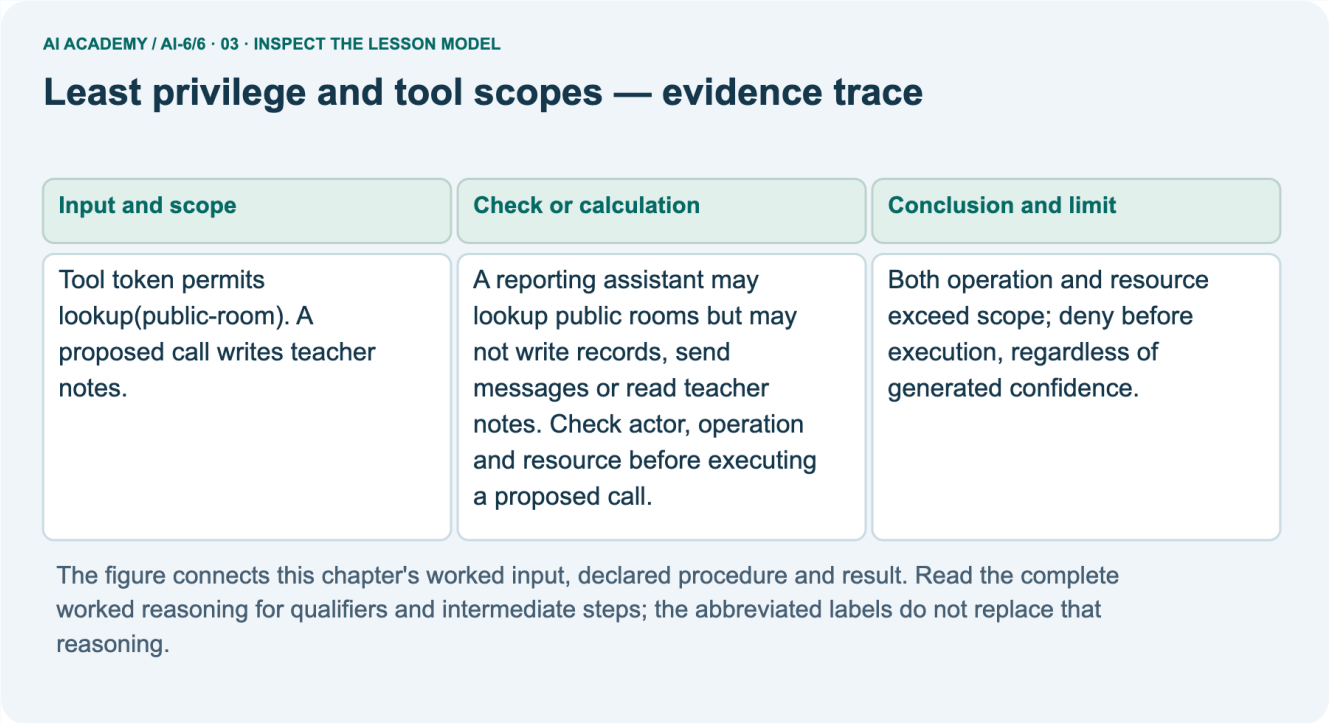


Follow the labelled picture with the matching explanation. Open the vector diagram

Match scope: Read S2 matches both the allowed operation and station. → Reject extra powers: Write S2 has the wrong operation; read S5 has the wrong station. → Run permitted call: Only read S2 may proceed.

> Point to each numbered stage and explain which recorded **input** it uses.

03. Least privilege and tool scopes — evidence trace



Follow the labelled picture with the matching explanation. Open the vector diagram

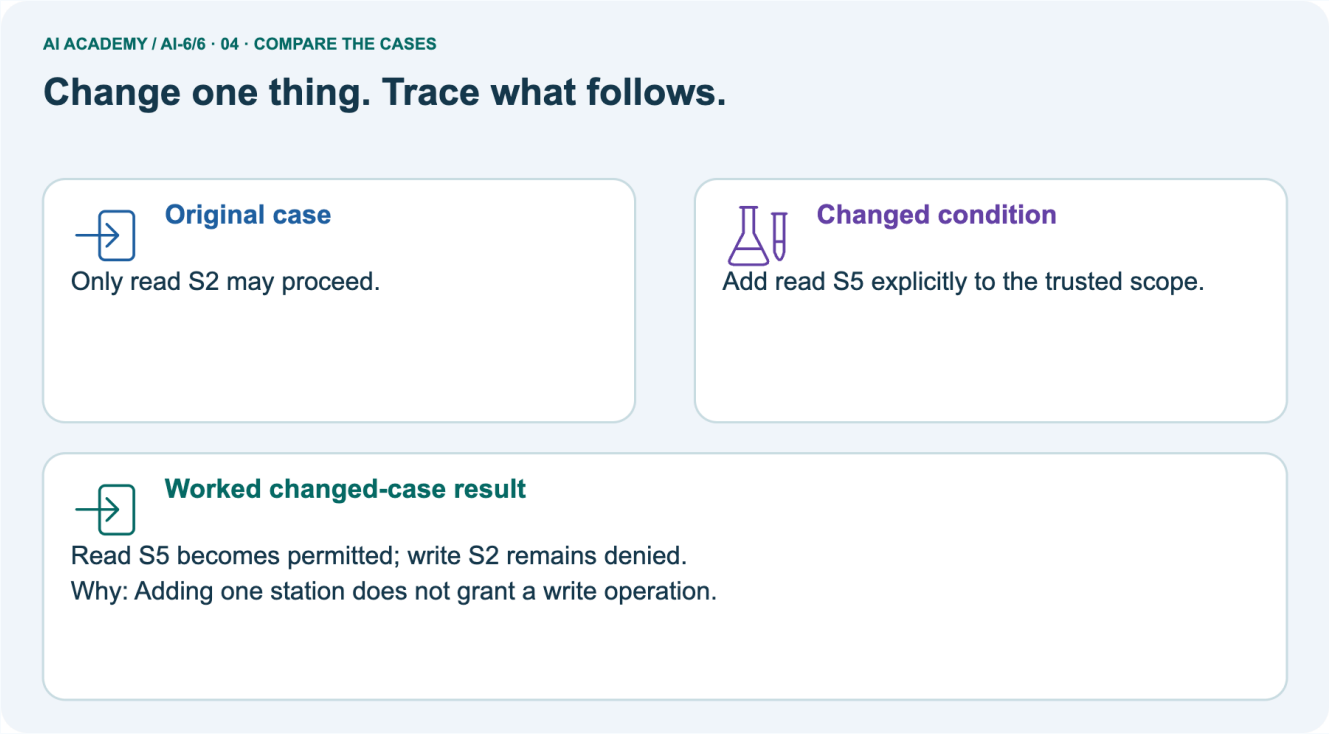
Least privilege and tool scopes — **evidence** trace. Tool token permits lookup(public-room).

A proposed call writes teacher notes. | A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes.

Check actor, operation and resource before executing a proposed call. | Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

> Read the labels and values. Explain the relationship the model shows.

04. Change one thing. Trace what follows.



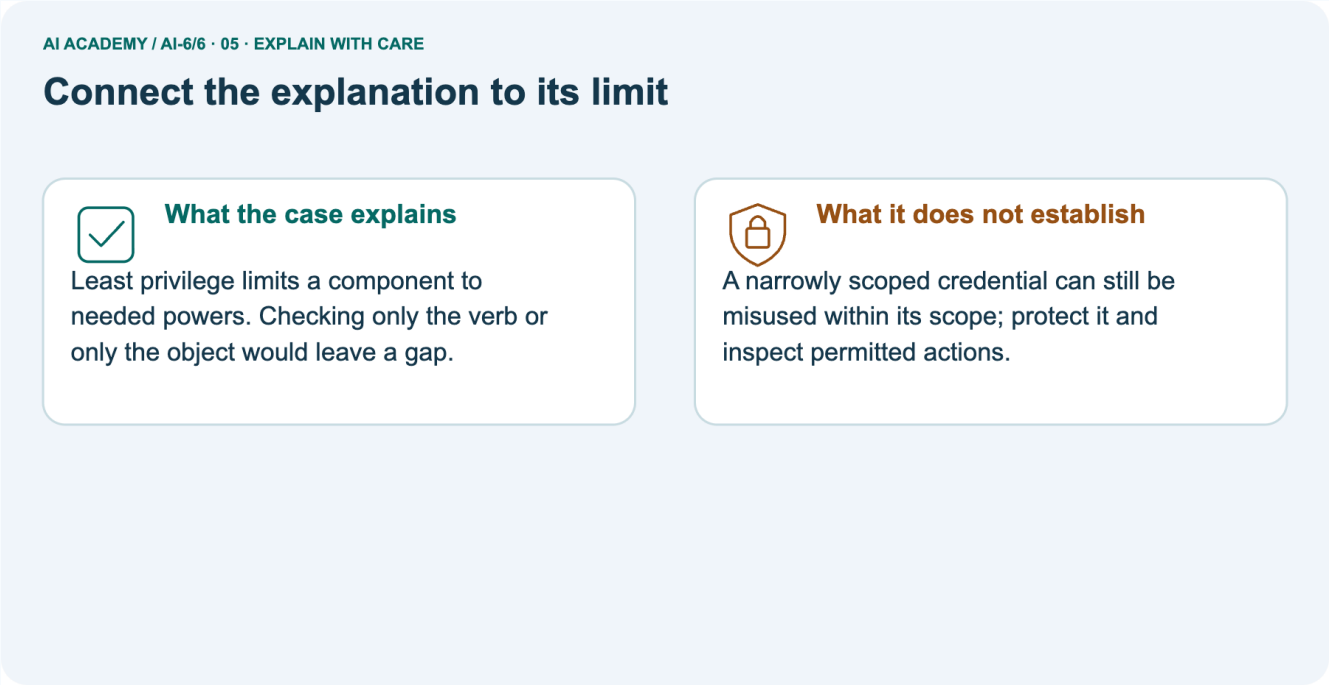
Follow the labelled picture with the matching explanation. Open the vector diagram

Original case: Only read S2 may proceed. Changed condition: Add read S5 explicitly to the trusted scope. Expected result: Read S5 becomes permitted; write S2 remains denied.

Reason: Adding one station does not grant a write operation.

> Predict before checking the worked changed-case result. Name what changed and what the supplied facts allow you to conclude.

05. Connect the explanation to its limit



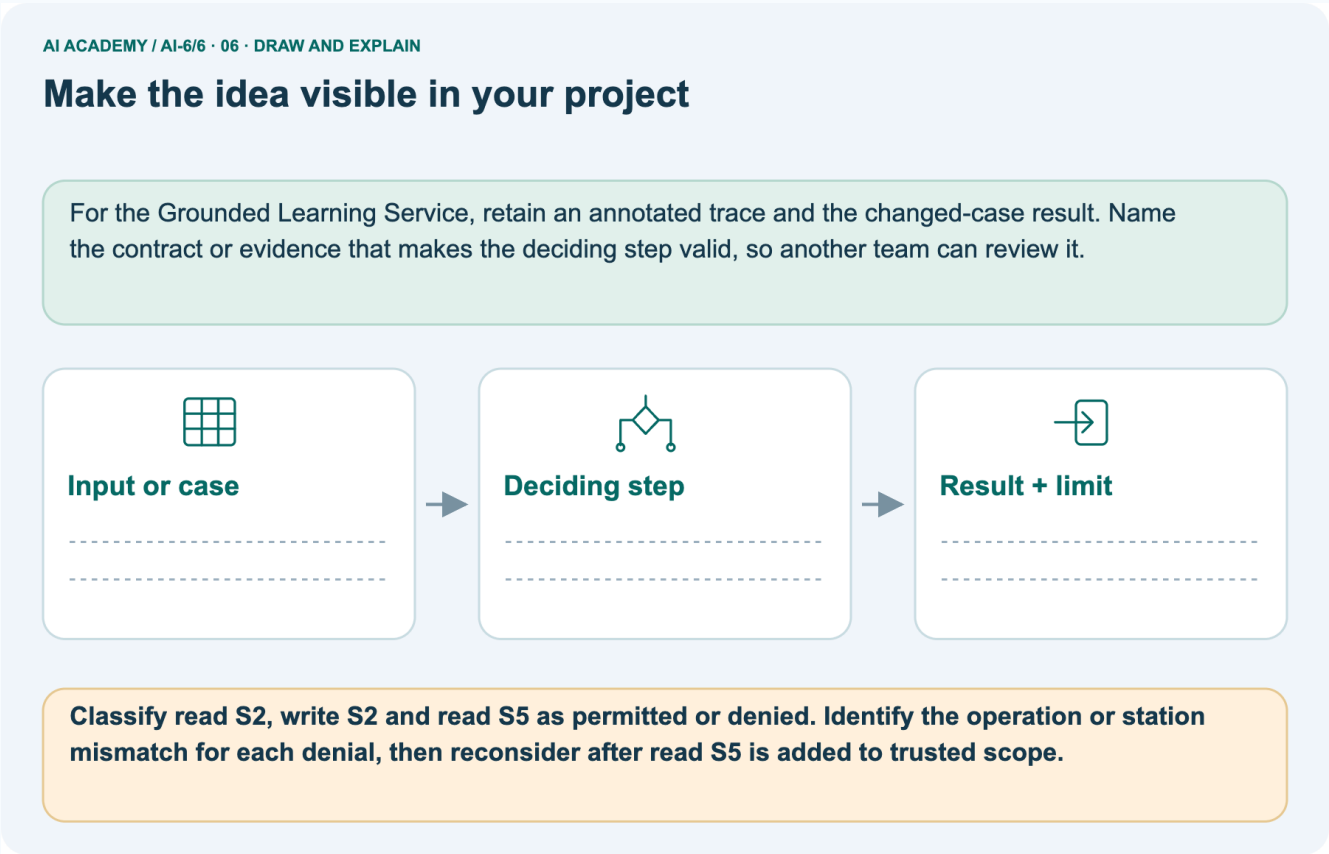
Follow the labelled picture with the matching explanation. Open the vector diagram

Least privilege limits a component to needed powers. Checking only the verb or only the object would leave a gap.

Limit: A narrowly scoped credential can still be misused within its scope; protect it and inspect permitted actions.

> Explain the case, then point to a limit on the claim.

06. Make the idea visible in your project



Follow the labelled picture with the matching explanation. Open the vector diagram

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

Draw your **input**, deciding step, result and limit. Supported question: Classify read S2, write S2 and read S5 as permitted or denied.

Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

> Draw your project trace and justify the deciding step using **evidence**.

Save or print your responses for your portfolio. Progress and drafts on the hosted website stay in the current browser. Use only fictional or teacher-approved data.